

● 10 Ago 2021

01

US\$ 611M

Poly Network

”US\$611M roubados — e devolvidos”

CROSS-CHAIN · CRITICAL

O maior hack de DeFi até então — atacante devolveu tudo e recebeu oferta de emprego

0 que aconteceu

02

Poly Network era uma bridge cross-chain que conectava Ethereum, BSC e Polygon, permitindo transferir ativos entre blockchains.

O atacante descobriu que podia **crafar uma mensagem cross-chain** que chamava a função interna de troca de **keeper** (administrador).

A função **_executeCrossChainTx** fazia um **call arbitrário** sem validar adequadamente o destino. O atacante **trocou o keeper para si mesmo**.

Com controle total, drenou **US\$611M** em múltiplas chains. Dias depois, devolveu tudo — alegando que “queria expor a vulnerabilidade”. A Poly Network ofereceu-lhe um cargo de **Chief Security Advisor**.

● Contrato Vulnerável

03

INHA VULNERÁVEL

● ● ● SOLIDITY / VULNERABLE

```
...ess, ) = _toContract.call( |abi.encodePacked(|
bytes4(keccak256(_method)), |_args |) |); }
```

Lição

Valide chamadas cross-chain com **whitelists de funções** — nunca permita calls arbitrários em contratos críticos.

Como o ataque funcionou

PASSO 1

Atacante cria mensagem cross-chain maliciosa



PASSO 2

Mensagem chama `_executeCrossChainTx`



PASSO 3

`_method = "putCurEpochConPubKeyBytes"`
(função que troca o keeper/admin)



PASSO 4

`_toContract.call()` → troca keeper para o atacante



PASSO 5

Atacante agora é admin de 3 bridges



RESULTADO

Drena US\$611M em ETH, BSC e Polygon

Devolveu tudo dias depois

● Verifique na Blockchain

05

Transação do Ataque (ETH)etherscan.io/tx/0xad7a2c...602aEndereço do Atacanteetherscan.io/address/0xC8a65...9963